# פרויקט קורס אבטחת המרחב המקוון

סמסטר 2026 א׳

חוקרים: דוד ונז׳יק וסהר דוד

# תקציר ומוטיבציה

מערכות אימות סיסמאות מהוות הן יעד לתקיפות אוטומטיות כגון Brute force ו-Password spraying.
במחקר זה בדקנו אילו שילובים של מנגנוני אחסון והגנה מצליחים לצמצם את אפקטיביות תקיפות אלה, בלי לפגוע בצורה משמעותית במערכת עצמה ובשימושיותה.

**טענת המחקר**

שילוב מנגנון אחסון חזק (Argon2) יחד עם מנגנוני ההגנה משלימים מסוג Rate limiting ו-TOTP מפחית את יעילות התקיפות בהשוואה לשימוש במנגנונים בודדים, תוך שינוי מאפייני העומס החישובי והשפעה מוגבלת על תהליך ההזדהות התקני של המשתמש.

# תצורה ניסוית

## סביבת הפיתוח







## שרת

- מימוש באמצעות Flask
- בסיס נתוני משתמשים בSQLite
- קובץ קונפיגורציה - config.json

## תיעוד לוגים

הלוגים תועדו בקובץ login_logs.json

# מטודולוגיה - מה בדקנו?

במסגרת המחקר בדקנו 2 שיטות תקיפה נפוצות, שלושה מנגנוני אחסון סיסמאות ובחנו את השפעתם של מספר מנגנוני הגנה נפוצים הן בנפרד והן בשילובים.

| סוגי תקיפות |
| --- |
| Brute force |
| Password spraying |

| מנגנוני הגנה |
| --- |
| Pepper |
| Account locking |
| Rate limiting |
| TOTP |
| Captcha |

| מנגנוני אחסון |
| --- |
| SHA256 |
| Bcrypt |
| Argon2id |

# מטודולוגיה - איך בדקנו?

**במסגרת המחקר ביצענו מספר ניסונות תקיפת Brute force ו-Password spraying על השרת תוך שילוב מנגנוני אחסון והגנה שונים. לכל ניסוי נלקחו מספר מדדים המאפשרים הבנה על אפקטיביות המנגנונים וההשפעה על החומרה.**

## מה נשאר זהה?

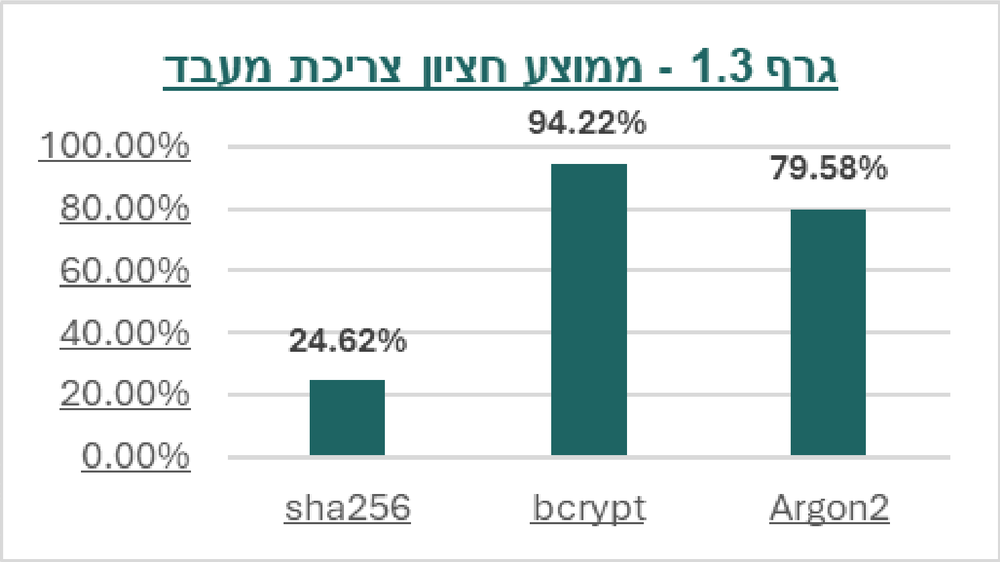
- בסיס נתונים של 30 משתמשים אשר סווגו לשלוש רמות חוזק סיסמה - חלשה, בינונית וחזקה.
- מילון סיסמאות נפוצות rockyou
- ביצוע הניסויים תחת קונפיגורציה קבועה - קובץ config.json

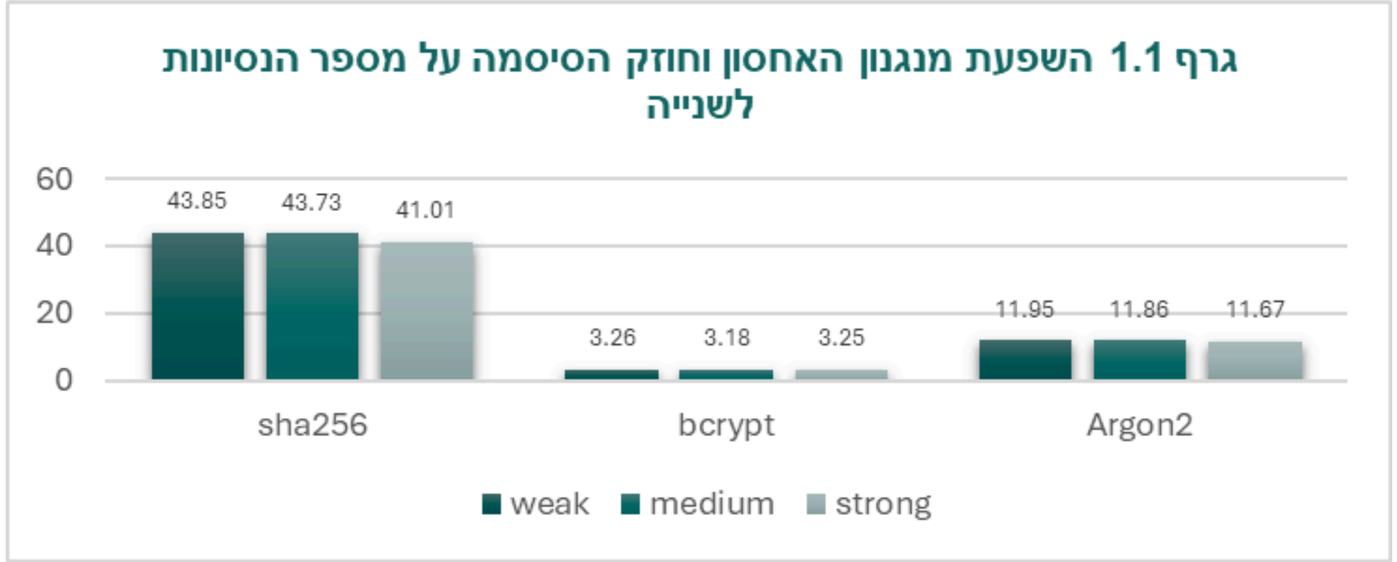
## מה מדדנו?



# תוצאות השוואת מנגנונים

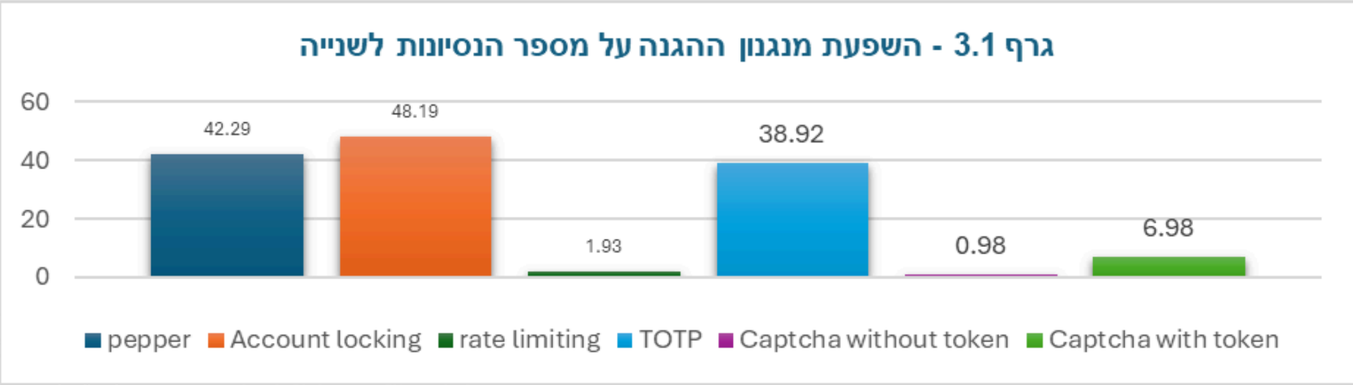
**SHA256 אפשר את קצב ניסיונות הגבוה ביותר, בעוד bcrypt הפחית את קצב התקיפה בצורה המשמעותית, ביותר במחיר שימוש CPU גבוה. Argon2 הציג תוצאה ביניים בקצב וב-CPU.**



# תוצאות שילוב מנגנוני הגנה
# Brute force

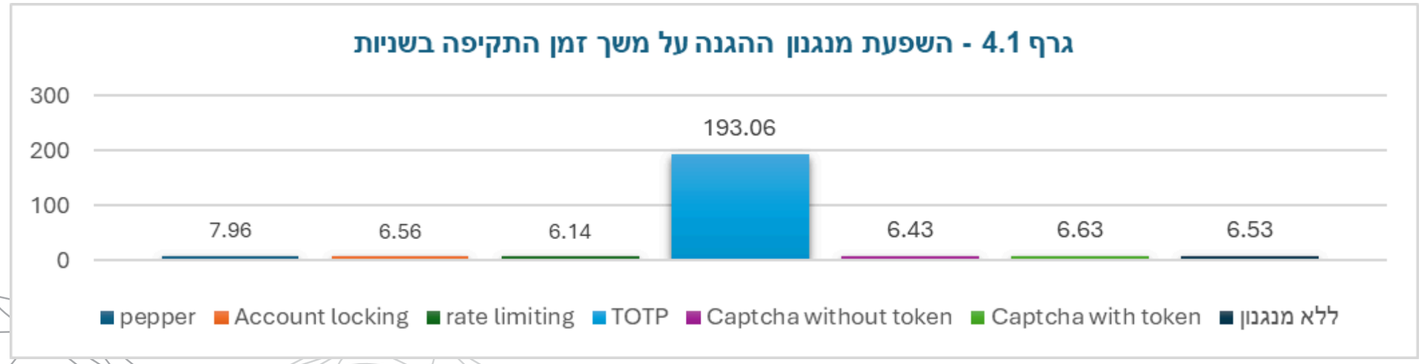
בתרחיש Brute force ניכר כי מנגנונים המגבילים ניסיונות התחברות ברמת משתמש מפחיתים משמעותית את קצב התקיפה, בעוד שמנגנוני TOTP ו-Account locking מנעו את הצלחת התקיפה.




| מדידת הצלחת התקיפה | | | |
|---|---|---|---|
| מנגנון הגנה | הצלחת תקיפה | מנגנון הגנה | הצלחת התקיפה |
| pepper | כן | TOTP | לא |
| Account locking | לא | Captcha בלי טוקן | כן |
| rate limiting | כן | captcha עם טוקן | כן |

# תוצאות שילוב מנגנוני הגנה
# Password spraying

בתרחיש Password spraying נצפתה יעילות מוגבלת של מנגנוני החסימה/האטה ברמת משתמש, בעוד שמנגנון TOTP מנע את הצלחת התקיפה והאריך משמעותית את משך ההתקפה.

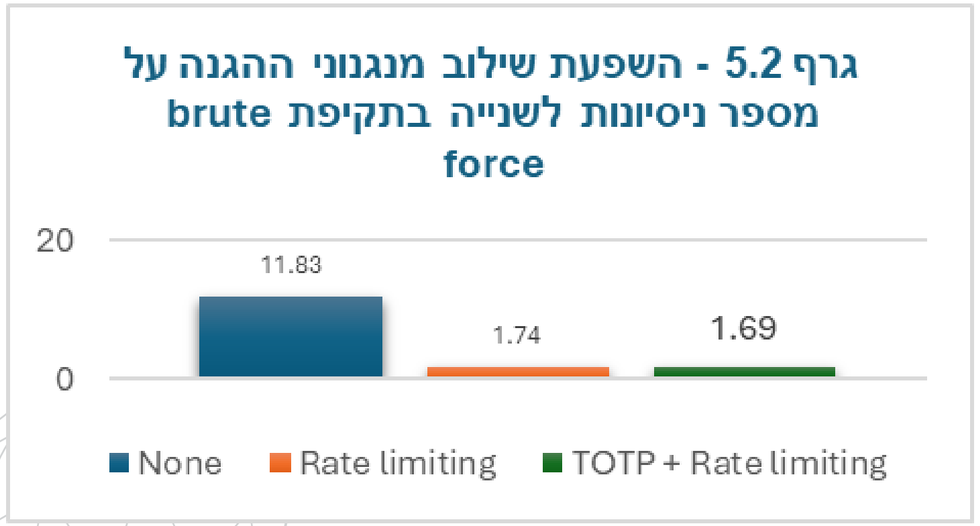



| מדידת הצלחת התקיפה | | | |
|---|---|---|---|
| מנגנון הגנה | הצלחת תקיפה | מנגנון הגנה | הצלחת התקיפה |
| pepper | כן | TOTP | לא |
| Account locking | כן | Captcha בלי טוקן | כן |
| rate limiting | כן | captcha עם טוקן | כן |

# שילוב נבחר

## Argon2 + TOTP + Rate limiting

שילוב מנגנוני ההגנה הציג ירידה חדה בקצב ניסיונות ההתחברות והפחתה משמעותית בסיכויי הצלחת התקיפה, בהשוואה להפעלת מנגנון יחיד.




| מדידת הצלחת תקיפה | | | | | |
|---|---|---|---|---|---|
| Password spraying | | | Brute force | | |
| מנגנון אחסון | מנגנון הגנה | הצלחת תקיפה | מנגנון אחסון | מנגנון הגנה | הצלחת תקיפה |
| Argon2 | ללא מנגנון הגנה | כן | Argon2 | ללא מנגנון הגנה | כן |
| Argon2 | Rate limiting | כן | Argon2 | Rate limiting | כן |
| Argon2 | TOTP + Rate limiting | לא | Argon2 | TOTP + Rate limiting | לא |

# דיון ומסקנות

1. שילוב המנגנונים TOTP, Argon2 ו-Rate limiting סיפק את רמת רמת ההתמודדות הגבוהה ביותר מבין התצורות שנמדדו.
2. מנגנוני אחסון הסיסמאות השפיעו  על קצב התקיפות ועל צריכת משאבי השרת.
3. TOTP מנע הצלחת תקיפה גם לאחר זיהוי סיסמה תקפה, בכל תרחישי התקיפה.
4. תקיפות Password spraying מפחיתות את יעילותם של Account locking, Rate limiting ו-Captcha.
5. הגדרות ספי ההפעלה של מנגנוני ההגנה משפיעות על יעילות ההגנה

# עבודה עתידית

## שיפורים אפשרים

1. הארכת משך הזמן המירבי לתקיפה.
2. שימוש במילון סיסמאות נפוצות עדכני יותר
3. הגדלת מספר המשתמשים בתרחישי התקיפה
4. הקטנת מספר הנסיונות הכושלים עד עצירה/השהייה במנגנוני Account locking, Rate limiting ו-captcha

## הרחבות עתידיות

1. הרחבת הניסוי לסוגי התקפות נוספות
2. הרחבת תרחישי התקיפה - ניסון פריצת מנגנון TOTP